

Sécurisation de l'usine GRFICS

Analyse des vulnérabilités exploitées en travaux pratiques, architecture cible, correctifs priorisés selon les niveaux de sécurité de l'IEC 62443 et plan de contingence.

INSTALLATION Réacteur chimique — GRFICSv3	PÉRIMÈTRE Zones ICS 192.168.95.0/24 & DMZ 192.168.90.0/24	RÉFÉRENTIEL IEC 62443-3-3 / 62443-3-2
COÛT D'INDISPONIBILITÉ 6 500 € par heure d'arrêt		

§1 Contexte et méthode

L'installation a été compromise en conditions d'exercice, jusqu'à l'**explosion du réacteur**. Le mode opératoire, rejoué pas à pas au TP, n'a exigé ni faille logicielle inédite, ni compétence rare : reconnaissance physique des lieux, mots de passe ramassés sur place, interception réseau, puis réécriture de la logique de l'automate. Le présent dossier part de cette intrusion pour établir ce qui doit être corrigé, dans quel ordre, à quel coût, et comment l'usine réagit si l'incident se reproduit.

Chaîne d'attaque reconstituée à partir du compte-rendu de TP

1. **Reconnaissance physique** — badge d'accès et porte mal fermée, secrets récupérés dans une poubelle, panneau IHM utilisable sans authentification, armoire électrique ouverte, routeur personnel branché sur le réseau. Mots de passe

obtenus : poste d'ingénierie (rangée basse du clavier), compte admin de l'automate, mot de passe du routeur sur un post-it.

2. **Découverte réseau** — depuis le poste attaquant 192.168.90.6, balayage nmap de la DMZ : IHM en 90.107:8080, routeur en 90.1 / 90.200 (DNS + interface d'administration 5000). L'automate est déduit sur un autre sous-réseau.
3. **Homme du milieu** — arpspoof entre l'IHM (90.107) et l'automate (95.2), ip_forward activé ; capture Wireshark des trames Modbus en clair, révélant le sous-réseau procédé 192.168.95.0/24.
4. **Cartographie du procédé** — nmap -p 502 sur la zone OT : six esclaves Modbus (Feed 1/2, Purge, Product, **Réacteur .95.14**, Analyzer) ; bannières relevées avec le module Metasploit modbus_banner_grabbing.
5. **Prise de l'automate** — accès noVNC du poste d'ingénierie (95.5:6080), ouverture du projet OpenPLC « chemical », injection de pressure_sp := 65535 ; : la consigne de pression est saturée, la vanne de purge ne s'ouvre plus, la pression monte sans régulation. Compilation, téléversement via l'interface web de l'automate, redémarrage → **explosion**.

La démarche suit la logique de l'**IEC 62443-3-2** : identifier le système à l'étude, le découper en *zones* et *conduits*, évaluer le risque pour chaque zone, puis attribuer à chacune un niveau de sécurité cible (SL-T) et en déduire les exigences fondamentales de l'**IEC 62443-3-3**. Les techniques d'attaque observées sont référencées avec le cadre **MITRE ATT&CK for ICS** afin de relier chaque correctif à un mode opératoire concret plutôt qu'à une exigence abstraite.

Rappel des niveaux de sécurité

SL 1	SL 2	SL 3	SL 4
Protection contre une violation fortuite ou accidentelle.	Attaquant intentionnel, moyens faibles, compétences génériques.	Attaquant motivé, moyens modérés, compétences spécifiques aux SI industriels.	Attaquant disposant de moyens étendus et de ressources d'État.

Le mode opératoire du TP — distribution Kali standard, identifiants par défaut, bibliothèque Modbus publique, plugin OT de Caldera — correspond exactement au profil **SL 2**. Or

l'installation n'oppose aujourd'hui **aucune** contre-mesure : elle se situe au niveau **SL 0**.

L'écart à combler est donc, au minimum, de SL 0 à SL 2 partout, et de SL 0 à **SL 3** sur la zone de contrôle, qui commande directement un procédé dangereux.

Chaque niveau se décline sur quatre axes définis par la norme : le **SL-T** (target, ce que l'on vise, issu de l'analyse de risque), le **SL-C** (capability, ce que le composant sait faire), le **SL-A** (achieved, ce qui est réellement atteint une fois installé) et le **SL 0** (aucune exigence). Le durcissement consiste à faire converger SL-A vers SL-T, zone par zone.

Les 7 exigences fondamentales (Foundational Requirements)

L'IEC 62443-3-3 décline chaque niveau de sécurité en sept familles d'exigences. Elles servent de grille de lecture aux correctifs du §5.

FR	EXIGENCE FONDAMENTALE	CE QU'ELLE IMPOSE ICI
FR 1	Contrôle d'identification & d'authentification (IAC)	Comptes nominatifs, mots de passe forts, MFA sur l'administration
FR 2	Contrôle d'usage (UC)	Droits par rôle, dépôt de programme automate restreint et tracé
FR 3	Intégrité du système (SI)	Signature du code automate, inspection Modbus, anti-usurpation ARP
FR 4	Confidentialité des données (DC)	TLS interne, fin du HTTP et du Modbus en clair sur les conduits sensibles
FR 5	Restriction des flux (RDF)	Zones & conduits, pare-feu en refus par défaut, suppression du réseau d'admin hors bande
FR 6	Réponse aux événements (TRE)	IDS Suricata paramétré, SIEM Wazuh, journalisation centralisée
FR 7	Disponibilité des ressources (RA)	Sauvegards hors ligne, PRA testé, barrière SIL 2 indépendante

§2 Architecture initiale

Deux sous-réseaux à plat séparés par un routeur Linux, lui-même ouvert en grand. Toutes les interfaces d'administration sont exposées en HTTP, tous les comptes sont ceux d'origine,

et le protocole de commande du procédé — Modbus/TCP — circule sans authentification ni contrôle d'intégrité.

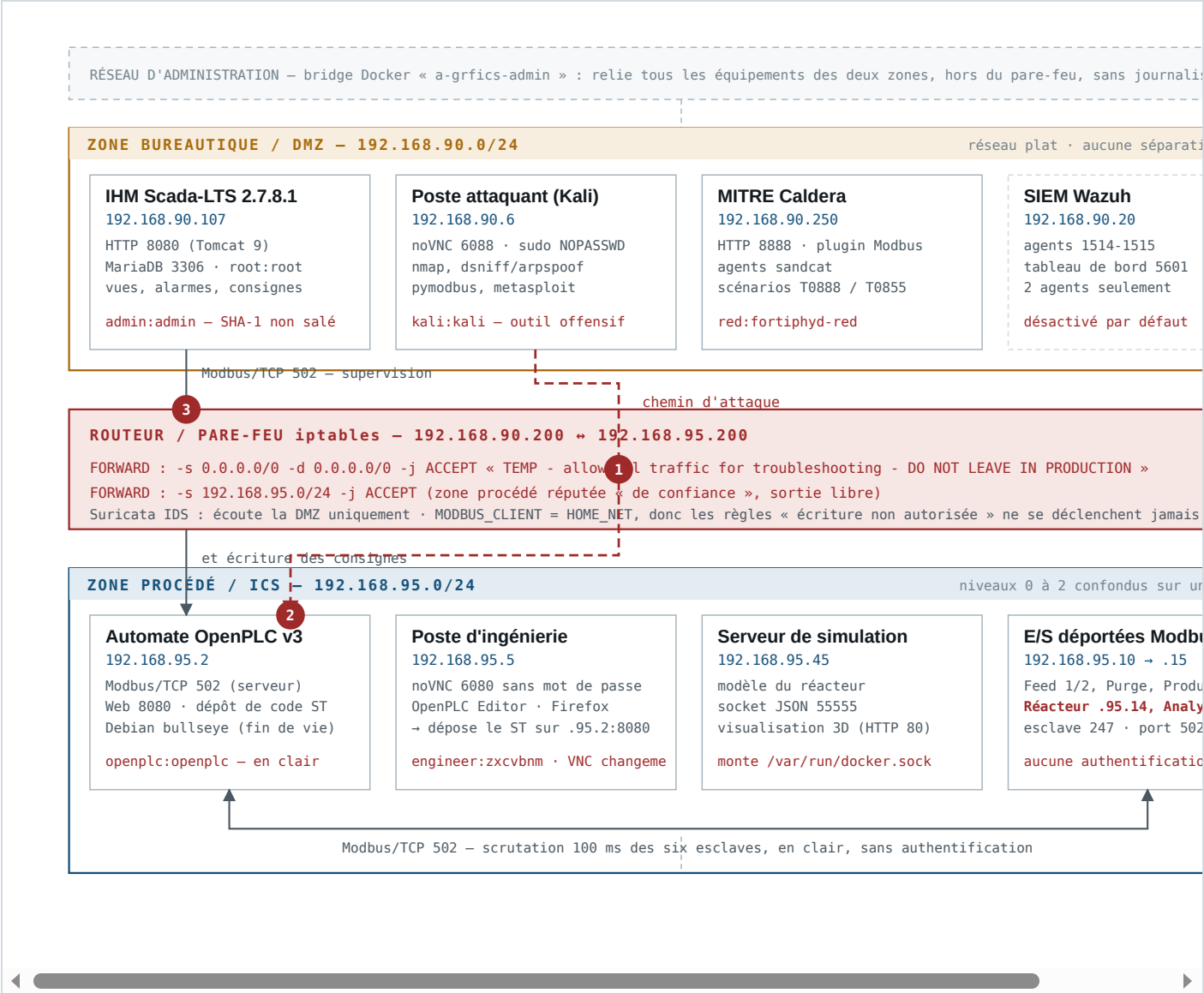


Planche 1 – Architecture initiale (état constaté). Chemin d'attaque rejoué au TP : **1** pivot de la DMZ vers la zone procédé, aucune règle ne s'y oppose · **2** prise de contrôle du poste d'ingénierie puis dépôt d'un programme ST piégé (pressure_sp := 65535) via l'interface web de l'automate · **3** usurpation ARP sur le flux IHM → automate pour masquer la dérive à l'opérateur. Résultat : explosion du réacteur (.95.14).

Matrice des flux constatés

SOURCE	DESTINATION	PROTOCOLE / PORT	USAGE	CONTRÔLE EN PLACE
IHM Scada-LTS .90.107	Automate .95.2	Modbus/TCP 502	Lecture des mesures, écriture des consignes	aucun

SOURCE	DESTINATION	PROTOCOLE / PORT	USAGE	CONTRÔLE EN PLACE
Automate .95.2	E/S déportées .95.10 - .15	Modbus/TCP 502	Scrutation 100 ms, commande des vannes	aucun
E/S déportées	Moteur de simulation .95.45	TCP 55555 (JSON)	Image du procédé physique	aucun
Poste d'ingénierie .95.5	Automate .95.2	HTTP 8080	Dépôt et démarrage du programme ST	mot de passe par défaut
Navigateurs (hôte)	IHM, automate, postes	HTTP 80/6080/6081/8080/8888	Exploitation et administration	en clair
Routeur, IHM	Wazuh .90.20	TCP 1514/1515	Journalisation (si activée)	partiel, 2 agents
Tous	Routeur .200	UDP 53 · TCP 5000	DNS et administration du pare-feu	HTTP, admin:password
Tous	Tous	bridge d'administration	Canal hors-bande non maîtrisé	hors pare-feu

§3 Analyse des vulnérabilités

Treize vulnérabilités ont été retenues. Chacune est rattachée aux exigences système (SR) de l'IEC 62443-3-3 et à la technique ATT&CK for ICS correspondante. Les cinq premières sont celles qui ont été directement exploitées pendant le TP ; elles conditionnent la totalité de la chaîne d'attaque.

v1 Pare-feu ouvert en grand entre la DMZ et la zone procédé

Critique

SR 5.1 · 5.2 · 7.6

SL atteint : 0

CONSTAT

La configuration livrée contient une unique règle -s 0.0.0.0/0 -d 0.0.0.0/0 -j ACCEPT, commentée « TEMP - allow all traffic for troubleshooting - DO NOT LEAVE IN PRODUCTION », complétée par un -s 192.168.95.0/24 -j ACCEPT permanent qui autorise toute sortie de la zone procédé.

EXPLOITATION

Depuis le poste Kali en DMZ, balayage puis accès direct à 192.168.95.2:502 et :8080. Aucun pivot, aucune élévation de privilèges nécessaire.

IMPACT	La segmentation n'existe que sur le schéma. Toute machine bureautique compromise atteint l'automate en une étape.
ATT&CK ICS	T0886 Remote Services · T0883 Internet Accessible Device

v2 Identifiants par défaut sur l'intégralité du parc

Critique

SR 1.1 · 1.5 · 1.7

SL atteint : 0

CONSTAT	Compte admin de l'automate deviné, mot de passe du poste d'ingénierie correspondant à la rangée basse du clavier, mot de passe du routeur affiché sur un post-it. Au niveau du parc : openplc:openplc (en clair dans openplc.db), admin:admin sur l'IHM (empreinte SHA-1 non salée 0DPiKuNIrrVmD8IUCuw1hQxNqZc=), mot de passe d'administration du pare-feu, root:root et scada:scada sur la base, mot de passe VNC par défaut sur le poste d'ingénierie, admin:admin sur le SIEM.
EXPLOITATION	Au TP, connexion directe aux interfaces d'administration sans exploitation de faille logicielle : c'est ce compte admin qui a permis de téléverser le programme piégé sur l'automate. Aucun compte nominatif, donc aucune imputabilité des actions.
IMPACT	Contrôle total de la chaîne de commande et effacement possible des traces.
ATT&CK ICS	T0859 Valid Accounts · T0812 Default Credentials

v3 Modbus/TCP sans authentification ni contrôle d'intégrité

Critique

SR 1.1 · 1.2 · 3.1 · 3.5

SL atteint : 0

CONSTAT	Le protocole ne porte ni identité, ni signature, ni horodatage. Les six esclaves (.10 à .15) et l'automate acceptent toute écriture de registre ou de bobine provenant de n'importe quelle adresse.
EXPLOITATION	Écriture directe des registres de commande de vannes avec pymodbus ou le plugin Modbus de Caldera, en contournant totalement la logique de régulation.
IMPACT	Ouverture ou fermeture arbitraire des vannes d'alimentation et de purge : montée en pression du réacteur jusqu'à la rupture, sans qu'aucune mesure logicielle ne s'y oppose.
ATT&CK ICS	T0855 Unauthorized Command Message · T0836 Modify Parameter · T0831 Manipulation of Control

v4 Dépôt de programme automate non contrôlé

Critique

SR 3.4 · 3.8 · 2.1

SL atteint : 0

CONSTAT	L'interface web de l'automate (port 8080) permet de téléverser un programme ST, de le compiler et de le passer en RUN. Le programme n'est ni signé, ni versionné, ni comparé à une référence ; l'automate ne dispose d'aucun commutateur RUN/PROG matériel. Le poste d'ingénierie (noVNC 95.5:6080) donne accès à l'éditeur OpenPLC et au projet « chemical » d'origine.
EXPLOITATION	C'est l'étape qui a détruit le réacteur. Ajout de <code>pressure_sp := 65535</code> ; en fin de programme : la consigne de pression est saturée au maximum, la logique n'ouvre plus la vanne de purge, la pression monte sans régulation. Export en <code>Attack.st</code> , téléversement via l'interface web, redémarrage de l'automate → explosion.
IMPACT	Persistance de l'attaquant dans l'organe de commande lui-même : la seule protection contre la suppression était cette logique, désormais retournée contre le procédé. Un redémarrage ne suffit pas à revenir à un état sain.
ATT&CK ICS	T0843 Program Download · T0889 Modify Program

v5 Usurpation ARP et interception des flux de conduite

Critique

SR 3.1 · 3.5 · 5.1

SL atteint : 0

CONSTAT	Les deux réseaux sont plats et commutés sans inspection ARP dynamique ni 802.1X. Le poste attaquant embarque <code>dsniff / arpspoof</code> et est configuré pour l'usurpation.
EXPLOITATION	Au TP : <code>sysctl -w net.ipv4.ip_forward=1</code> puis <code>arpspoof</code> croisé entre l'IHM (90.107) et l'automate (95.2). Wireshark (filtre <code>modbus/arp</code>) a capturé les trames Modbus en clair et révélé le sous-réseau procédé 192.168.95.x — c'est ce qui a ouvert la porte vers la zone OT.
IMPACT	Perte de confiance dans la supervision — l'opérateur ne peut plus détecter l'incident ni décider d'un arrêt.
ATT&CK ICS	T0830 Adversary-in-the-Middle · T0856 Spoof Reporting Message · T0832 Manipulation of View

v6 Administration en clair (HTTP, VNC)

Majeur

SR 3.1 · 4.1 · 4.2

SL atteint : 0

CONSTAT	Automate (8080), IHM (8080), pare-feu (5000), bureaux distants noVNC (6080/6088), visualisation (80) : tout est en HTTP. Le cookie de session du pare-feu est signé avec la clé par défaut <code>some-long-secret-you-generate</code> .
EXPLOITATION	Capture des identifiants par écoute passive après usurpation ARP ; forge d'un cookie d'administration du pare-feu sans connaître le mot de passe.

IMPACT	Compromission des accès d'administration, y compris de l'équipement de filtrage lui-même.
ATT&CK ICS	T0842 Network Sniffing · T0860 Wireless Compromise (n/a ici)

v7 Détection inopérante : IDS mal paramétré, zone procédé non surveillée

Majeur

SR 6.1 · 6.2

SL atteint : 0

CONSTAT	Suricata n'écoute que l'interface DMZ (<code>ids_monitor = {LAN: false, DMZ: true}</code>). Les règles Quickdraw « écriture Modbus non autorisée » sont écrites <code>!\$MODBUS_CLIENT</code> , or la variable vaut <code>HOME_NET</code> , c'est-à-dire <i>tout</i> le plan d'adressage privé : la règle ne peut jamais se déclencher.
EXPLOITATION	L'ensemble des écritures Modbus malveillantes du TP n'a généré aucune alerte.
IMPACT	Aucune chance de détecter l'attaque avant l'effet physique. C'est le correctif au meilleur rapport coût / bénéfice de tout le plan.
ATT&CK ICS	Défaut de couverture — contre-mesure des techniques T0855 / T0843

v8 Journalisation absente ou non centralisée

Majeur

SR 2.8 · 2.9 · 2.11 · 6.1

SL atteint : 0

CONSTAT	Le SIEM est facultatif et désactivé par défaut. Seuls deux agents existent (routeur, IHM) : ni l'automate, ni le poste d'ingénierie, ni le serveur de simulation ne remontent quoi que ce soit. Pas de source de temps commune.
EXPLOITATION	Aucune trace du dépôt de programme ni des écritures Modbus ; analyse post-incident impossible.
IMPACT	Ni détection, ni imputabilité, ni preuve en cas de déclaration réglementaire.
ATT&CK ICS	T0872 Indicator Removal on Host (facilité)

v9 Composants obsolètes et non corrigés

Majeur

SR 3.10 · 7.2

SL atteint : 0

CONSTAT	L'automate tourne sur Debian bullseye, en fin de vie, dont le dépôt de sécurité a été explicitement retiré de la configuration. Scada-LTS 2.7.8.1 sur Tomcat 9, empreintes SHA-1 non salées. Mots de passe en clair dans la base de l'automate. Aucun inventaire ni processus de correctifs.
---------	--

EXPLOITATION	Non exploité au TP, mais constitue le réservoir de failles pour une attaque ultérieure.
IMPACT	Surface d'attaque croissante et impossibilité de démontrer la maîtrise des versions.
ATT&CK ICS	T0866 Exploitation of Remote Services

V10 Réseau d'administration hors périmètre et accès à l'hyperviseur

Majeur

SR 5.1 · 7.7

SL atteint : 0

CONSTAT	Un réseau d'administration commun relie tous les équipements des deux zones sans passer par le pare-feu. Le serveur de simulation monte en outre la socket de l'hôte de virtualisation (/var/run/docker.sock).
EXPLOITATION	Contournement complet du filtrage ; depuis le serveur de simulation, contrôle de l'hôte et donc de tous les équipements virtualisés.
IMPACT	Tout l'effort de segmentation devient caduc si ce canal subsiste.
ATT&CK ICS	T0812 Default Credentials · évasion de conteneur

V11 Outillage offensif hébergé en production

Modéré

SR 7.8 · 2.1

SL atteint : 0

CONSTAT	Un poste Kali et un serveur Caldera équipé du plugin Modbus sont raccordés en permanence à la DMZ, avec des identifiants publics.
EXPLOITATION	L'attaquant n'a pas eu besoin d'apporter ses outils : ils étaient déjà sur le réseau, prêts à l'emploi.
IMPACT	Réduction drastique du coût d'entrée d'une attaque et pollution de l'inventaire des actifs.
ATT&CK ICS	T0862 Supply Chain Compromise (analogie)

V12 Aucune barrière de sécurité indépendante du système de conduite

Critique

IEC 61511 · 62443-3-2

SL atteint : 0

CONSTAT	La seule protection contre la suppression du réacteur est la logique de l'automate — c'est-à-dire précisément l'organe que l'attaquant contrôle. Ni capteur indépendant, ni automate de sécurité, ni interlock câblé, ni organe de décharge.
EXPLOITATION	La compromission de l'automate suffit à conduire le procédé jusqu'à la destruction.
IMPACT	Conséquences humaines et environnementales, au-delà du coût d'indisponibilité. C'est le fondement du plan de contingence du §7.

v13 Hygiène physique et organisationnelle

Modéré

62443-2-1 · SR 2.1

SL atteint : 0

CONSTAT	Relevés lors de la visite du TP : badge d'accès disponible et porte mal fermée, secrets et mots de passe jetés dans une poubelle, panneau IHM utilisable sans authentification, armoire électrique ouverte, routeur personnel branché sur le réseau, et une fontaine à eau adossée à un local électrique. Aucune séparation des espaces bureautiques et industriels.
EXPLOITATION	C'est le point de départ réel de l'attaque : les mots de passe du routeur et de l'automate ont été obtenus <i>physiquement</i> , avant toute action réseau. Un accès de quelques minutes donne les mêmes pouvoirs qu'une intrusion à distance, sans laisser de trace.
IMPACT	Contournement de toutes les mesures logiques mises en place.
ATT&CK ICS	T0864 Transient Cyber Asset · T0847 Replication Through Removable Media

Classification physique / logique / logicielle

Les treize vulnérabilités se rangent en trois familles, qui appellent des correctifs de nature différente : la sensibilisation pour le physique, l'architecture réseau pour le logique, le durcissement des composants pour le logiciel.

FAMILLE	RÉF	VULNÉRABILITÉ	CORRECTIF TYPE	SL VISÉ
Physique	V13	Porte de zone calée par un parpaing, badge/carte d'accès laissés traîner, armoire électrique ouverte, fontaine près du local technique	Politique d'accès, contrôle des portes anti-maintenance-ouvert, verrouillage des armoires, audit de site périodique	SL 1-2
	V13	Mots de passe sur post-it, recette/secrets jetés dans une poubelle	Formation & sensibilisation (affiches, charte, « clean desk »), coffre-fort de secrets, destruction sécurisée des documents	SL 1
Logique (réseau)	V1	Pare-feu ouvert (« allow all »), zones à plat	Refus par défaut, zones & conduits, une règle par flux	SL 2-3
	V5	Usurpation ARP / homme du milieu (TP1)	Voir l'encadré ci-dessous — DAI, port-	SL 3

FAMILLE	RÉF	VULNÉRABILITÉ	CORRECTIF TYPE	SL VISÉ
			security, 802.1X	
	V3 · V10	Modbus non authentifié, réseau d'administration hors bande, accès à l'hyperviseur	Pare-feu à inspection Modbus, segmentation cellule, suppression du canal hors bande	SL 3
Logicielle (hôtes)	V2 · V6	Identifiants par défaut, administration en clair (HTTP/VNC)	Comptes nominatifs + MFA, TLS interne, désactivation de HTTP	SL 2
	V4	Dépôt de programme automate non contrôlé	Programme signé, empreinte vérifiée, interface d'ingénierie fermée en exploitation	SL 3
	V7 · V8 · V9 · V11	IDS aveugle, journalisation absente, composants en fin de vie, outils offensifs sur site	Suricata + SIEM, gestion des correctifs, inventaire et retrait des outils	SL 2
Sûreté	V12	Aucune barrière de sécurité indépendante du système de conduite	Automate de sécurité SIL 2, interlock câblé, organe de décharge (IEC 61511)	SL 3

Les 9 vulnérabilités physiques relevées sur site

Relevées à l'identique par les trois binômes lors de la visite de l'usine (V13). Elles ne coûtent presque rien à corriger et constituent la première ligne de défense : sans elles, tout l'effort logique et logiciel peut être contourné en quelques minutes d'accès physique.

#	VULNÉRABILITÉ CONSTATÉE	CORRECTIF PROPOSÉ	NATURE
1	Porte sécurisée par lecteur de carte, maintenue ouverte par un parpaing	Capteur de porte maintenue ouverte + alarme, ferme-porte, sensibilisation (ne jamais caler une porte)	Organisation
2	Mot de passe affiché sur un post-it	Coffre-fort de secrets (gestionnaire de mots de passe), politique « clean desk », affiches de rappel	Organisation
3	Second mot de passe sur post-it	Idem : proscrire tout secret sur papier, rotation des mots de passe exposés	Organisation
4	Carte d'accès (badge) laissée sur le bureau	Port du badge obligatoire et personnel, ne jamais le laisser sans surveillance, désactivation immédiate en cas de perte	Organisation
5	Routeur en libre accès	Armoire réseau verrouillée, désactivation des ports inutilisés, port-security sur les	Physique

#	VULNÉRABILITÉ CONSTATÉE	CORRECTIF PROPOSÉ	NATURE
		ports actifs	
6	Automate (PLC) laissé ouvert / accessible	Armoire automate verrouillée à clé, commutateur RUN/PROG physique, accès en zone contrôlée	Physique
7	IHM utilisable sans authentification	Verrouillage de session automatique, authentification obligatoire, écran en zone à accès restreint	Logiciel
8	Recette (procédé) non détruite, jetée dans la corbeille	Destruction sécurisée (broyeur), politique de gestion documentaire, marquage « confidentiel »	Organisation
9	Fontaine à eau à côté de l'automate	Éloigner tout liquide des équipements électriques, règles d'implantation, bac de rétention	Sécurité

Le correctif transverse : formation et sensibilisation

Huit des neuf points relèvent du comportement, pas de la technique. La mesure la plus efficace et la moins chère est donc un programme de sensibilisation : affiches en zone, charte de sécurité signée, exercices réguliers, et intégration de ces règles à l'accueil des nouveaux arrivants. C'est le correctif C17, au meilleur rapport coût/efficacité de tout le plan pour la couche physique.

Focus : empêcher l'usurpation ARP et l'homme du milieu (V5)

Le problème observé au TP

Sur un réseau commuté « à plat », n'importe quelle machine peut envoyer de fausses réponses ARP (arpspoof) pour se faire passer pour la passerelle ou pour l'automate. Le trafic Modbus IHM ↔ automate transite alors par le poste attaquant, qui peut le lire (Wireshark) et le réécrire. Aucune de ces techniques n'exploite une faille : elles abusent d'un protocole (ARP) sans authentification.

Les contre-mesures, de la plus simple à la plus robuste

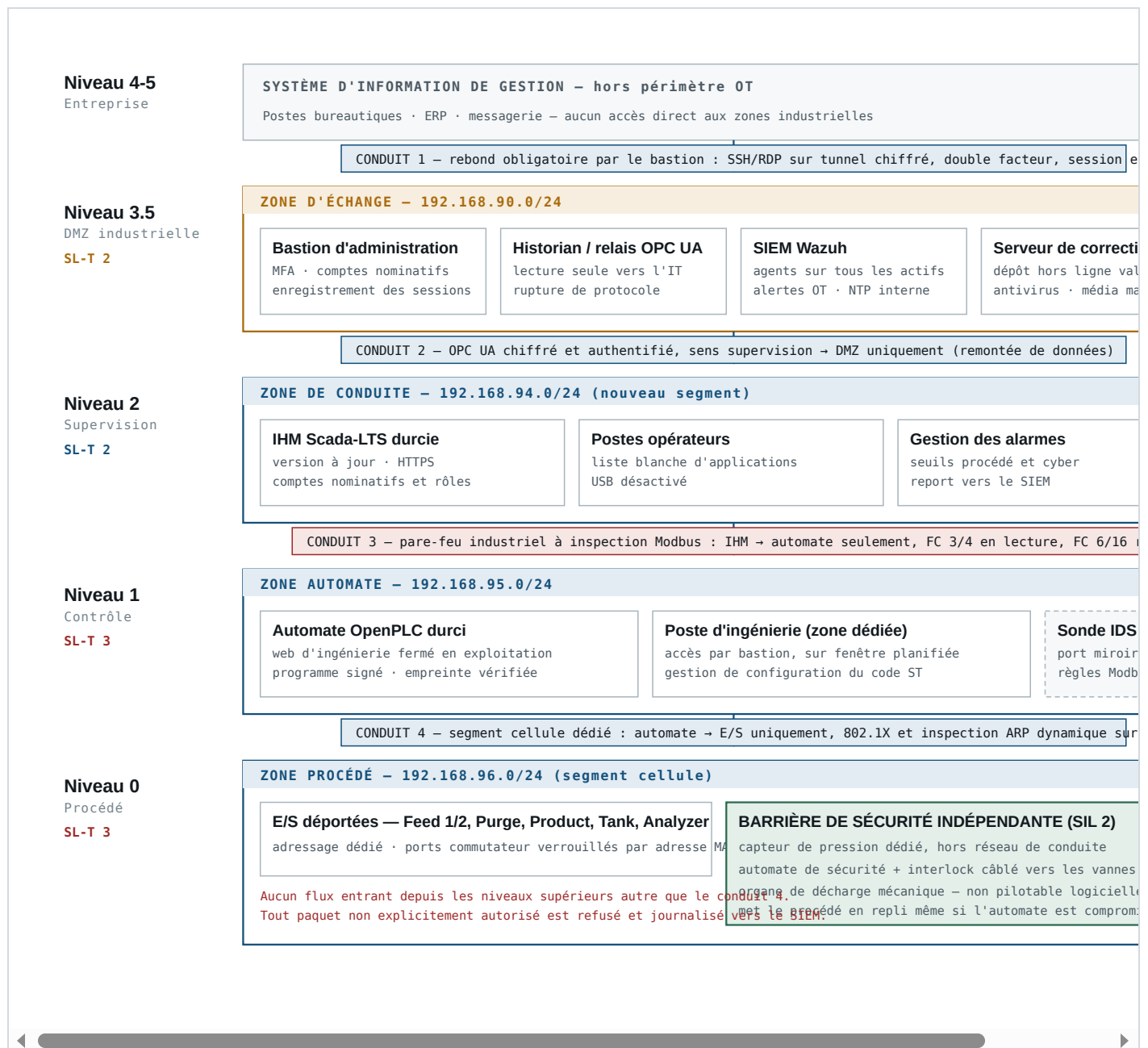
- **Dynamic ARP Inspection (DAI)** sur les commutateurs — chaque réponse ARP est vérifiée contre la table DHCP snooping ; les réponses forgées sont rejetées. *C'est la parade directe à l'arpspoof.*

- **Port security / sticky MAC** — un port ne laisse passer qu'une adresse MAC apprise ; brancher un équipement pirate (le « routeur perso » du TP) coupe le port.
- **802.1X** — authentification de l'équipement avant tout accès au réseau ; une machine non enrôlée ne parle à personne.
- **Entrées ARP statiques** sur les liens critiques peu nombreux (IHM ↔ automate) — simple, robuste, mais à maintenir manuellement.
- **Segmentation en VLAN / conduits** — réduit le domaine de diffusion : un attaquant en DMZ ne peut plus usurper un équipement de la cellule.
- **Protocoles authentifiés** — à terme, Modbus/TCP Security (TLS) ou OPC UA signé rendent la réécriture des trames inopérante, même si l'interception réussit.

Combinées, DAI + port-security + 802.1X ferment la quasi-totalité des attaques de niveau 2 vues en TP1, et sont portées par les commutateurs industriels du correctif C13.

§4 Architecture cible

L'architecture cible applique le découpage en zones et conduits de l'IEC 62443-3-2 sur un modèle Purdue. Chaque zone reçoit un niveau de sécurité cible, chaque conduit n'autorise qu'une liste explicite de flux, et tout le reste est refusé *et journalisé*. Le principe directeur : un flux qui n'est pas nécessaire à la conduite du procédé n'a pas de raison d'exister.



Matrice des conduits

CONDUIT	SOURCE → DESTINATION	PROTOCOLE AUTORISÉ	RESTRICTION	CONTRÔLE
C2	Supervision (N2) → DMZ	OPC UA (TLS, certificat)	Sens unique, données de production uniquement	Rupture de protocole sur l'historian
C3	IHM (N2) → Automate (N1)	Modbus/TCP 502	Une seule adresse source ; FC 3/4 en lecture, FC 6/16 limités aux registres de consigne et bornés en valeur	Pare-feu industriel à inspection applicative + IDS
C3b	Poste d'ingénierie → Automate	HTTPS 8080	Ouvert uniquement pendant une fenêtre de maintenance déclarée	Bastion, MFA, validation à deux personnes
C4	Automate (N1) → E/S (N0)	Modbus/TCP 502	Segment cellule isolé, aucune autre source	802.1X, inspection ARP dynamique, verrouillage MAC
C5	Tous → SIEM (N3.5)	Agent chiffré 1514/1515	Sens unique, journaux uniquement	Agent sur chaque actif, horloge commune
Tout flux non listé : refusé et journalisé. Le réseau d'administration hors bande est supprimé.				

Vue « après » — l'architecture initiale, corrigée

La même installation que la planche 1, correctif par correctif, pour comparer l'avant et l'après d'un seul regard. Les blocs verts sont les mesures ajoutées.

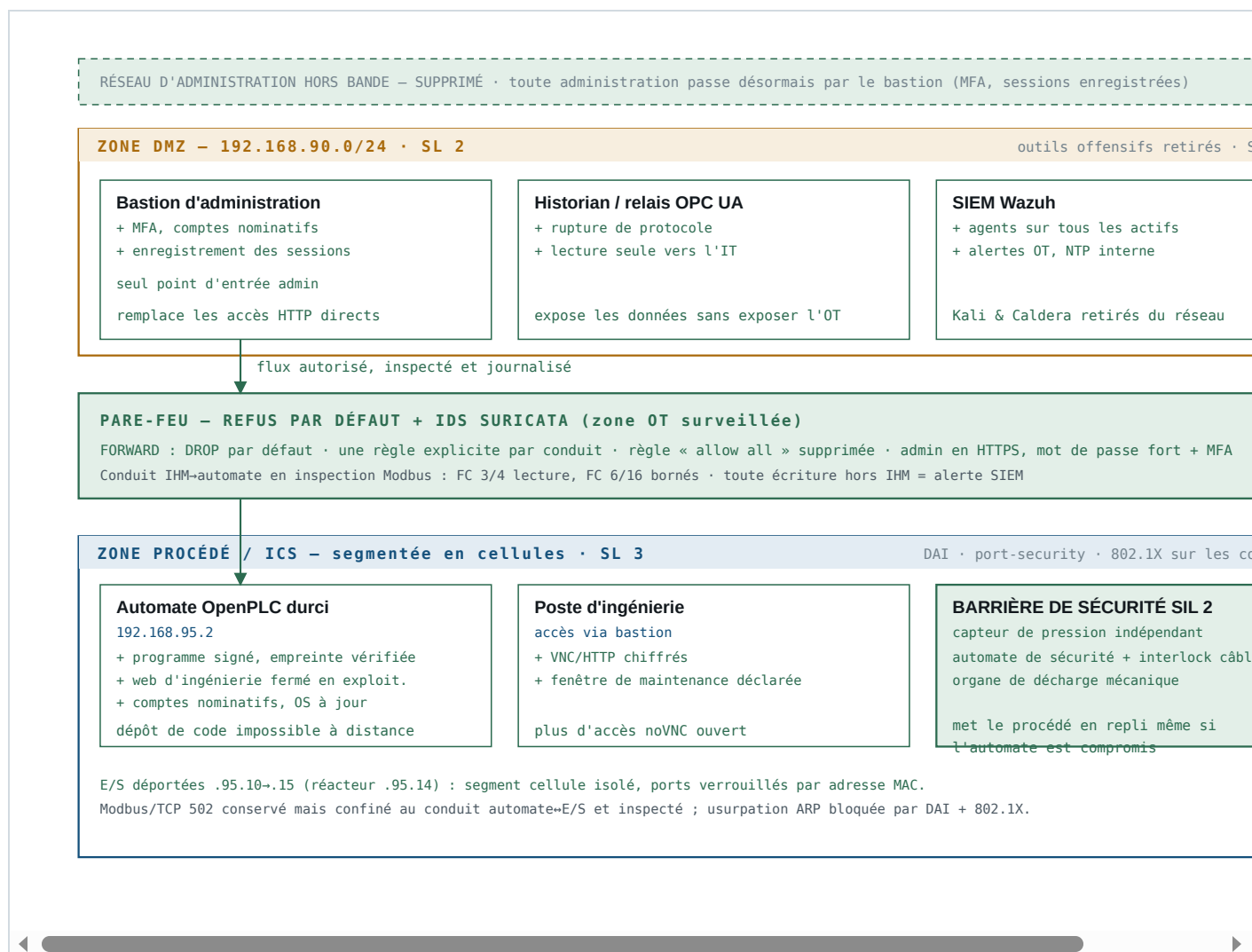


Planche 3 – Architecture finale, en miroir de la planche 1. Même disposition (DMZ · pare-feu · ICS) pour la comparaison directe. En vert, les correctifs ajoutés : bastion + MFA, SIEM, pare-feu en refus par défaut avec inspection Modbus, IDS étendu à l'OT, automate durci et signé, segmentation par cellules (DAI/802.1X), et la barrière de sécurité SIL 2 indépendante. Le réseau d'administration hors bande a disparu.

§5 Correctifs, priorisation et coûts

La priorisation suit l'écart entre le niveau atteint (SL 0) et le niveau cible de chaque zone, pondéré par l'effet sur la chaîne d'attaque réelle. Un correctif qui coupe le chemin d'attaque du TP passe avant un correctif qui durcit un composant déjà inatteignable.

Hypothèses de chiffrage : **480 €** par jour d'ingénieur interne, **950 €** par jour de prestataire spécialisé en systèmes industriels, **6 500 €** par heure d'arrêt de production.

222 570 € PROGRAMME COMPLET, ARRÊTS INCLUS	134 820 € SI LES TRAVAUX SONT ADOSSÉS AUX ARRÊTS PLANIFIÉS	17 850 € LOT 0 – CHAÎNE D'ATTAQUE COUPÉE EN 2 SEMAINES	468 000 € COÛT D'UN INCIDENT TYPE TP (72 H D'ARRÊT)
--	--	--	---

PROGRAMME
COMPLET, ARRÊTS
INCLUS

SI LES TRAVAUX
SONT ADOSSÉS
AUX ARRÊTS
PLANIFIÉS

LOT 0 - CHAÎNE
D'ATTAQUE
COUPÉE EN 2
SEMAINES

COÛT D'UN
INCIDENT TYPE
TP (72 H
D'ARRÊT)

Lot 0 — Urgent : couper la chaîne d'attaque (0 à 2 semaines, SL 0 → SL 2)

Pourquoi ce lot d'abord

Il représente **8 % du budget** et supprime les trois premiers maillons de la chaîne d'attaque du TP : le pivot libre, les identifiants par défaut et l'absence totale de détection. À lui seul, il fait passer les deux zones de SL 0 à SL 2, c'est-à-dire au niveau exactement suffisant pour résister au profil d'attaquant rencontré.

RÉF	CORRECTIF	VULN.	SR	CHARGE	MATÉRIEL	ARRÊT	COÛT
C7	Bastion d'administration avec double facteur, suppression des accès directs aux interfaces techniques	V2 V6	1.1 1.13 2.6	3 j int. + 3 j ext.	2 500	0	6 790 €
C8	TLS interne (PKI) sur toutes les interfaces	V6	3.1 4.1	4 j int.	300	0	2 220 €
Sous-total lot 1						2 h	37 240 €

RÉF	CORRECTIF	VULN.	SR	CHARGE	MATÉRIEL	ARRÊT	COÛT
	d'administration, désactivation de HTTP et du VNC non chiffré						
C9	Durcissement de l'automate : interface de programmation fermée en exploitation, comptes nominatifs, DNP3/EtherNet-IP désactivés, sortie de la distribution en fin de vie	V4 V9	3.4 3.10 7.2	2 j int. + 5 j ext.	—	1 h	12 216
C10	Déplacement de l'IHM vers la zone de conduite (N2) et mise en place du relais OPC UA en DMZ	V1 V10	5.1 5.2	1 j int. + 5 j ext.	—	1 h	11 736
C11	Durcissement de Scada-LTS : montée de version, rôles, condensats robustes, comptes de base de données dédiés	V2 V9	1.5 1.7 3.10	1 j int. + 3 j ext.	—	0	3 336
C12	Journalisation des accès d'administration, source de temps interne commune	V8	2.8 2.11	2 j int.	—	0	960
Sous-total lot 1						2 h	37 240 €

Lot 2 — Structurel (3 à 12 mois, SL 3 sur les zones de contrôle et de procédé)

RÉF	CORRECTIF	VULN.	SR	CHARGE	MATÉRIEL	ARRÊT	
C13	Re-segmentation physique : deux commutateurs industriels de niveau 3 (VLAN par zone, inspection ARP dynamique, 802.1X), suppression du réseau d'administration hors bande	V5 V10	5.1 5.2 1.2	2 j int. + 8 j ext.	6 400	2 h	2
C14	Pare-feu industriel à inspection applicative Modbus : liste blanche de codes fonction et bornage des valeurs de consigne	V3	3.1 3.5 5.2	1 j int. + 6 j ext.	8 500	1 h	2
C15	Barrière de sécurité indépendante : capteur de pression dédié, automate de sécurité SIL 2, interlock câblé et organe de décharge mécanique	V12	IEC 61511	5 j int. + 10 j ext.	32 000	8 h	9
C16	Sauvegardes hors ligne, plan de reprise testé, jumeau numérique pour valider les modifications avant déploiement	V4 V9	7.3 7.4	6 j int.	1 500	0	
C17	Formation des équipes d'exploitation et de maintenance	V13	62443-2-1	2 j int. + 6 j ext.	–	0	
Sous-total lot 2						11 h	167

RÉF	CORRECTIF	VULN.	SR	CHARGE	MATÉRIEL	ARRÊT	
	(20 personnes) et exercice de crise annuel						
C18	Audit de conformité IEC 62443-3-3 et test d'intrusion sur le jumeau numérique	toutes	62443- 2-4	12 j ext.	—	0	1
Sous-total lot 2						11 h	167

Matrice facilité × coût × efficacité

Pour arbitrer, chaque correctif est noté sur trois axes : la **facilité** de mise en place (rapidité, absence d'arrêt, compétences requises), le **coût** complet, et l'**efficacité** sur la chaîne d'attaque réelle. Les mesures en haut du tableau — faciles, peu coûteuses, très efficaces — sont les « quick wins » à faire immédiatement.

RÉF	CORRECTIF	FACILITÉ	COÛT	EFFICACITÉ	VERDICT
C4	Paramétrage de l'IDS (variable Modbus, zone OT)	●●●	●○○	●●●	quick win
C2	Éradication des mots de passe par défaut	●●●	●○○	●●●	quick win
C1	Pare-feu en refus par défaut	●●○	●○○	●●●	quick win
C3	Retrait des outils offensifs (Kali, Caldera)	●●●	●○○	●●○	quick win
C5	SIEM Wazuh + agents + alertes OT	●●○	●●○	●●●	prioritaire
C17	Formation & sensibilisation (vulns physiques)	●●●	●●○	●●○	prioritaire
C7·C8	Bastion + MFA, TLS interne	●●○	●●○	●●●	prioritaire
C13	Re-segmentation physique (DAI, 802.1X)	●○○	●●●	●●●	structurel
C14	Pare-feu industriel à inspection Modbus	●○○	●●●	●●●	structurel
C15	Barrière de sécurité SIL 2 indépendante	●○○	●●●	●●●	incontournable

Lecture : ●●● facile / peu coûteux / très efficace — ●○○ difficile / coûteux / peu efficace.

Le coût élevé de C15 (barrière SIL 2) est assumé : c'est la seule mesure qui protège le procédé *même si tout le numérique est compromis*. Les quick wins, eux, offrent le meilleur rapport et n'exigent presque aucun arrêt.

Lecture économique

Sur les 222 570 € du programme, **87 750 € ne sont pas des dépenses de sécurité mais de l'indisponibilité** (13,5 h × 6 500 €). En adossant les travaux aux arrêts de maintenance déjà planifiés — notamment les 8 h de la barrière de sécurité — le coût réel tombe à **134 820 €**. C'est le premier levier d'arbitrage à présenter à la direction.

En regard, l'incident rejoué en TP conduit à un arrêt d'au moins 72 h le temps de restaurer l'automate, requalifier le procédé et expertiser le réacteur, soit **468 000 €** de production perdue — hors dommages matériels, conséquences humaines et environnementales. Le programme complet se rembourse en **moins d'un incident évité** ; le lot 0, en moins de trois heures d'arrêt.

§6 Stratégie de mise en exécution

Une usine ne se sécurise pas en arrêtant la production. La stratégie repose sur trois principes : valider hors ligne, grouper les arrêts, et ne jamais déployer sans point de retour.

SEMAINES 1 À 2 – LOT 0

Reprise de contrôle

Travaux réalisables en marche, à l'exception d'une fenêtre de 30 minutes pour la bascule du pare-feu. Séquence : rédaction des règles à partir de la matrice des conduits, essai sur le jumeau numérique, déploiement en mode « journalisation seule » pendant 72 h pour détecter les flux légitimes oubliés, puis passage en blocage effectif avec procédure de retour arrière préparée. La rotation des identifiants est menée en parallèle, équipement par équipement, avec consignation dans le coffre-fort.

MOIS 1 À 3 – LOT 1

Consolidation des accès

Le bastion et le chiffrement se déploient sans impact procédé. Les deux heures d'arrêt (automate et IHM) sont regroupées sur **une seule fenêtre technique**, de préférence lors d'un arrêt hebdomadaire existant : coût marginal nul au lieu de 13 000 €. Chaque modification passe par une demande de changement formalisée, avec essai préalable sur le jumeau numérique et validation de l'exploitant.

MOIS 3 À 12 – LOT 2

Refonte structurelle

Le recâblage, le pare-feu industriel et la barrière de sécurité représentent 11 h d'arrêt. Ils sont **intégralement adossés à l'arrêt annuel de maintenance**, ce qui neutralise les 71 500 € d'indisponibilité correspondants. La mise en service de la barrière SIL 2 suit le cycle de l'IEC 61511 : spécification, réalisation, essais de bon fonctionnement documentés, puis exploitation avec tests périodiques.

EN CONTINU

Maintien en condition de sécurité

Comité mensuel de suivi, revue trimestrielle des règles de filtrage, application des correctifs sur fenêtre planifiée après qualification, exercice de crise annuel, et audit de conformité en fin de programme pour attester le niveau atteint.

Indicateurs de pilotage

- **Couverture du filtrage** — part des flux passant par une règle explicite (cible : 100 %, mesure hebdomadaire sur les journaux de refus).
- **Comptes par défaut restants** — cible zéro dès la semaine 2, vérifié par balayage automatisé.
- **Délai de détection** — temps entre une écriture Modbus illégitime injectée en test et l'alerte SIEM (cible : moins de 5 minutes).
- **Actifs journalisés** — part des équipements remontant au SIEM (cible : 100 %).
- **Restauration testée** — délai de remise en service de l'automate depuis la sauvegarde de référence (cible : moins de 2 h, testé deux fois par an).

Facteurs de risque du programme

- Un blocage trop précoce du pare-feu peut interrompre un flux non documenté — d'où la phase obligatoire de journalisation seule.

- La montée de version de l'automate doit être qualifiée sur le jumeau numérique : une régression de la logique de régulation coûterait plus cher que la vulnérabilité corrigée.
- La disponibilité du prestataire spécialisé conditionne les lots 1 et 2 : à contractualiser dès le lancement.

§7 Plan de contingence

Le plan part d'un principe assumé : l'attaque réussira un jour. L'objectif n'est pas de l'empêcher absolument, mais de garantir que l'usine sait la voir, l'arrêter et redémarrer proprement.

PHASE	DÉCLENCHEUR	ACTION	RESPONSABLE	OBJECTIF
Détection	Alerte SIEM (écriture Modbus hors IHM, dépôt de programme, connexion hors fenêtre) ou écart entre mesure procédé et modèle attendu	Qualification de l'alerte par l'astreinte, vérification croisée avec le capteur indépendant	Astreinte exploitation	< 15 min
Qualification	Alerte confirmée	Ouverture de la cellule de crise, gel des modifications, préservation des journaux et d'une capture réseau	Responsable SSI + chef de quart	< 30 min
Confinement	Compromission avérée	Coupure du conduit supervision → automate, isolement de la zone concernée, passage en conduite locale ; la barrière SIL 2 reste active et indépendante	Chef de quart	< 1 h
Éradication	Périmètre établi	Restauration du programme automate depuis la sauvegarde hors ligne après vérification d'empreinte, réinitialisation des secrets, reconstruction des postes compromis	Équipe automatisme + prestataire	< 4 h
Reprise	Environnement sain	Essais de bon fonctionnement, redémarrage progressif selon la procédure de démarrage à froid,	Exploitation	< 8 h

PHASE	DÉCLENCHEUR	ACTION	RESPONSABLE	OBJECTIF
		surveillance renforcée pendant 72 h		
Retour d'expérience	Procédé stabilisé	Analyse de la chaîne d'attaque, mise à jour des règles de filtrage et de détection, déclaration réglementaire	Responsable SSI	< 5 j

Modes dégradés prévus

- **Conduite locale** — pilotage depuis les coffrets en salle de contrôle, réseau de supervision débranché. L'usine produit en capacité réduite plutôt que de s'arrêter : chaque heure ainsi préservée vaut 6 500 €.
- **Repli sûr automatique** — la barrière SIL 2 met le réacteur en position de sécurité sans intervention humaine et sans dépendance au réseau.
- **Supervision de secours** — poste opérateur hors domaine, avec la dernière configuration IHM validée, stocké hors ligne.

Sauvegardes et points de retour

- Programme automate signé et empreinte SHA-256 conservés hors ligne, vérifiés à chaque modification (objectif de perte de données : la dernière version validée).
- Configuration IHM, règles de pare-feu et images système en trois exemplaires, dont un hors site et un hors ligne.
- Test de restauration complet deux fois par an, chronométré, sur le jumeau numérique.

Obligations et parties prenantes

Un incident affectant la conduite du procédé relève d'une déclaration au régulateur national dans les délais prévus par la directive **NIS 2** pour les entités concernées (alerte précoce sous 24 h, notification sous 72 h). La cellule de crise intègre : direction d'usine, responsable SSI, responsable HSE, intégrateur automatisme, assureur, et le cas échéant l'autorité compétente. La liste de contacts est maintenue hors ligne, sur support papier, en salle de contrôle — elle doit rester lisible quand le système d'information ne l'est plus.

L'installation part de zéro : pare-feu ouvert, identifiants d'origine, protocole de commande sans authentification, aucune détection, aucune barrière physique indépendante. La chaîne d'attaque rejouée en TP n'a exigé ni faille logicielle inédite, ni compétence rare.

C'est aussi ce qui rend le redressement accessible : **17 850 €** et deux semaines suffisent à couper cette chaîne et à porter l'installation au niveau SL 2, celui qui correspond au profil d'attaquant rencontré. Les lots suivants portent la zone de contrôle à SL 3 et, surtout, réintroduisent une sécurité *physique* que la compromission du numérique ne peut pas annuler.

La question posée à la direction n'est donc pas « faut-il dépenser 222 570 € ? » mais « accepte-t-on de rester exposé à un arrêt de 468 000 € que quatre jours de travail bien ciblés rendent improbable ? ».